

# 15. Riesgos y deuda técnica

PDF Reader v0.3.0 | Análisis 2026-09-10 | Commit 265b122

Este registro describe el estado observado; no implica que los hallazgos se hayan corregido.

| Hallazgo                                          | Severidad                 | Probabilidad      | Evidencia/ubicación                  | Recomendación                                            | Prioridad |
|---------------------------------------------------|---------------------------|-------------------|--------------------------------------|----------------------------------------------------------|-----------|
| Carga completa y copias de PDF en memoria         | Alta                      | Media             | loadFile, loadPdfData, plugin Base64 | límites globales, medición y transferencia más eficiente | P1        |
| PDF.js/Electron/WebView procesan contenido hostil | Alta                      | Media             | arquitectura y dependencias          | actualizaciones rápidas, corpus/fuzz, CSP                | P1        |
| Historial local sin cifrado/expiración            | Alta para datos sensibles | Media             | IndexedDB guarda Blob                | política de retención y advertencia clara                | P1        |
| android:allowBackup=true                          | Alta para privacidad      | Variable          | AndroidManifest.xml                  | decidir si excluir datos y probar backups                | P1        |
| Cobertura centrada en utilidades                  | Media                     | Alta              | 9 tests; sin E2E                     | Playwright/Web, Electron y Android real                  | P1        |
| app.js concentra UI, dominio y plataforma         | Media                     | Alta              | módulo denso con unas 40 funciones   | separar controladores por responsabilidad                | P2        |
| Colisión de identidad por metadatos               | Media                     | Baja/Media        | documentKey, historyId               | hash parcial/UUID por documento                          | P2        |
| Guardado y poda en dos transacciones              | Baja                      | Baja              | saveHistoryDocument                  | una transacción o cursor por índice                      | P3        |
| Miniaturas no virtualizadas                       | Media                     | Alta en PDF largo | botón por página, canvas hasta 120   | virtualización/cancelación                               | P2        |
| Búsqueda secuencial completa                      | Media                     | Alta en PDF largo | searchDocument                       | progreso cancelable/worker/índice                        | P2        |
| Sin diálogo de contraseña                         | Media                     | Media             | friendlyPdfError                     | flujo dedicado sin registrar secreto                     | P2        |
| Sin OCR                                           | Baja                      | Media             | especificación/no objetivo           | mantener límite visible o evaluar OCR local              | P3        |
| Windows sin Authenticode                          | Media                     | Alta              | docs/release/config                  | firma y timestamping                                     | P2        |
| Prueba Android plantilla                          | Baja                      | Alta              | ExampleUnitTest.java                 | sustituir por pruebas del plugin                         | P3        |
| Sin lint/formato/cobertura/SAST dedicado          | Media                     | Alta              | package.json, workflows              | incorporar gates gradualmente                            | P2        |
| Actions referenciadas por tags mutables           | Alta                      | Media             | todos los uses: ...@vN               | fijar a SHA y automatizar renovación                     | P1        |

| Hallazgo                                | Severidad  | Probabilidad | Evidencia/ubicación              | Recomendación                                 | Prioridad |
|-----------------------------------------|------------|--------------|----------------------------------|-----------------------------------------------|-----------|
| Versiones repetidas manualmente         | Media      | Alta         | JS, package, Gradle, README/docs | script de sincronización/verificación         | P2        |
| Logs/monitorización de runtime ausentes | Baja/Media | Alta         | no identificados                 | mantener privacidad; diagnóstico opt-in local | P3        |

## Problemas confirmados frente a riesgos

Confirmados: cobertura funcional limitada, prueba Android trivial, falta de Authencicode, falta de diálogo de contraseña, ausencia de OCR, miniaturas no virtualizadas y marcadores de versión duplicados. Potenciales: explotación de parsers, colisiones de identidad, exposición por backup y agotamiento de memoria; requieren pruebas para cuantificar impacto.

## Módulos obsoletos o duplicados

No se identifica código fuente abandonado. `src/about.html` es una redirección de compatibilidad; los Markdown raíz cortos son fachadas deliberadas. `android/app/capacitor.build.gradle` es generado y no debe editarse manualmente. Los informes `validation-v0.1.0/v0.2.0` son evidencia histórica y deben conservar cifras antiguas.

## Decisiones que requieren validación humana

- retención y backup de PDF recientes;
- umbral de tamaño aceptable por plataforma;
- coste/gestión de Authencicode y distribución en tiendas;
- prioridad entre contraseñas, virtualización, OCR y accesibilidad;
- telemetría: el producto declara cero y cualquier cambio altera su promesa central.